

AdoptaFácil MVP — Documento de Requerimientos Técnicos

Módulo 1: Registro, Clasificación y Validación de Organizaciones

Campo	Valor
Versión del documento	1.0
Fecha	Julio 2026
Basado en	Documento del cliente "ADOPTAFÁCIL MVP V1 — Documento Técnico de Requerimientos Funcionales, v1.1"
Equipo	2 desarrolladores
Metodología de desarrollo	Desarrollo asistido por IA (IDE Antigravity) + revisión cruzada por Pull Request

1. Descripción general

AdoptaFácil es una plataforma para organizaciones de protección animal. El Módulo 1 cubre el ciclo completo de vida institucional de una organización dentro del sistema: registro, clasificación (Comunitaria/Informal o Formal), validación administrativa, observación y subsanación, rechazo, formalización progresiva, gestión segura de la firma virtual del Representante Legal, generación de documentos con firmantes dinámicos, emisión de reportes formales con flujo hacia DIAN, y auditoría inmutable de todas las acciones.

Principio rector del cliente: una organización puede entrar al sistema en un estado mínimo operativo (informal) y evolucionar a formal **sin perder su identificador interno, historial ni trazabilidad**.

2. Alcance

2.1 Incluido (In-Scope)

1. Registro inicial de organizaciones con datos de identificación y contacto.
2. Clasificación funcional: Comunitaria/Informal o Formal.
3. Carga y administración de documentos institucionales (Cámara de Comercio, RUT, certificados, logo, firma).
4. Flujos administrativos: revisión, observación con subsanación, rechazo, aprobación, suspensión.

- 5. Formalización progresiva (Informal → Formal) conservando el mismo ID interno.
- 6. Gestión de firma virtual del Representante Legal con almacenamiento cifrado.
- 7. Registro de identidad real del Representante Legal.
- 8. Permisos por rol y por nivel de formalidad (RBAC de 4 roles).
- 9. Alineación dinámica de firmantes en contratos y documentos (sin nombres hardcoded).
- 10. Generación de reportes tributarios y certificados de donación (solo organizaciones formales).
- 11. Flujo técnico de envío a DIAN con reintentos automáticos (simulado/mock en el MVP).
- 12. Persistencia de historial de cambios y auditoría inmutable de toda acción relevante.
- 13. Visualización del estado institucional en la interfaz y notificaciones de cambios de estado.
- 14. Detección de duplicidad de organizaciones (NIT, razón social, cámara de comercio, correo institucional).
- 15. Marcado de organizaciones inactivas (más de 12 meses sin actividad).

2.2 Excluido (Out-of-Scope)

- 1. Validación externa en tiempo real con Cámara de Comercio, DIAN u otras entidades (la integración DIAN del MVP será un mock con el contrato de datos preparado para integración real futura).
- 2. Firma electrónica certificada con validez legal externa vinculante.
- 3. Gestión contable interna, facturación electrónica comercial, nómina o personal.
- 4. Consulta pública de expedientes sensibles.
- 5. Eliminación física de registros históricos aprobados o auditados.
- 6. Generación de documentos que simulen validez formal para organizaciones no formalizadas.
- 7. Modificación de datos auditados sin rastro histórico.

3. Stack tecnológico definido

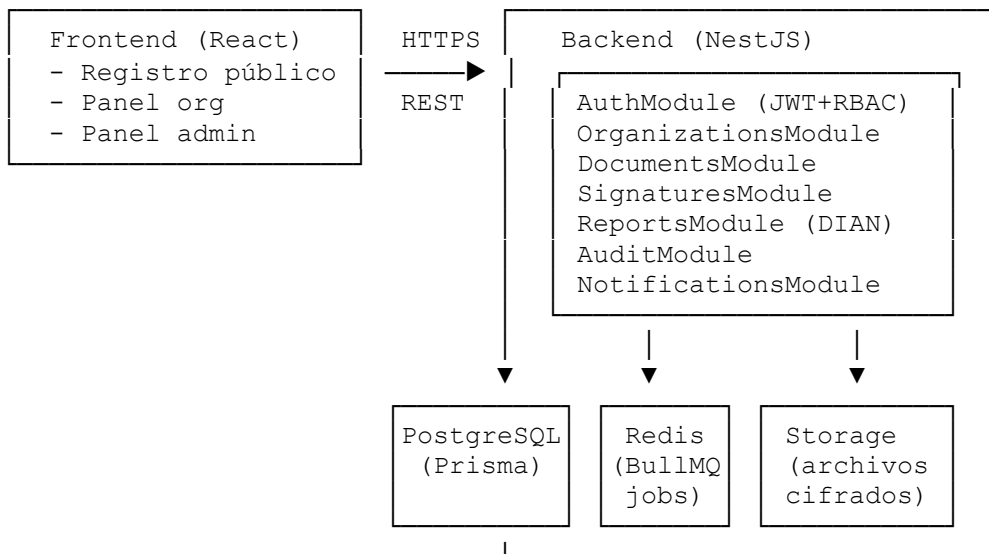
Decisión: **TypeScript de extremo a extremo**, alineado con la experiencia del equipo y optimizado para desarrollo asistido por IA.

Capa	Tecnología	Justificación
Frontend	React 18 + TypeScript + Vite	SPA para formularios complejos y panel administrativo; ecosistema con máxima documentación
Estilos	Tailwind CSS + shadcn/ui	Iteración rápida por prompt; componentes accesibles (tablas, modales, badges de estado, formularios)

Capa	Tecnología	Justificación
Estado del cliente	TanStack Query (React Query)	Cacheo y sincronización de datos del servidor; evita gestores de estado complejos
Validación compartida	Zod	Mismos esquemas de validación en frontend (React Hook Form) y backend (pipes de NestJS)
Formularios	React Hook Form + Zod	Formularios de registro multi-paso con guardado de progreso parcial
Backend	NestJS (Node.js 20 LTS + TypeScript)	Arquitectura modular que mapea 1:1 con los módulos del documento; guards nativos para RBAC; inyección de dependencias que facilita el mock de DIAN
ORM	Prisma	Migraciones versionadas en Git (esencial para 2 devs); soporte nativo de UUID y JSONB
Base de datos	PostgreSQL 16	UUIDs, JSONB para <code>previous_state/new_state</code> del <code>audit_log</code> , transacciones ACID (requeridas por la regla de rollback de firma §4.6 del cliente)
Autenticación	JWT (access + refresh tokens) con Passport.js	Estándar, integrable con los guards de roles
Cifrado de firma	AES-256-GCM (módulo <code>crypto</code> de Node) con clave en variables de entorno	La firma nunca se persiste en texto plano ni se expone por URL pública
Almacenamiento de archivos	Sistema de archivos local en MVP, detrás de endpoints autenticados (abstracción <code>StorageService</code> para migrar a S3/Supabase después)	Cumple la regla de no exponer documentos por URLs públicas
Jobs y reintentos	BullMQ + Redis	Reintentos programados hacia DIAN: 5 min → 30 min → 2 h → 24 h
Generación de PDF	pdf-lib o Puppeteer (plantillas HTML)	Contratos y certificados con datos de firmantes resueltos dinámicamente
Notificaciones	Nodemailer (SMTP) en MVP	Notificar transiciones: Observado, Aprobado, Rechazado, Suspendido, Formal
Testing	Vitest (front) + Jest/Supertest (back)	Pruebas de la máquina de estados y de la matriz de permisos como mínimo obligatorio

Capa	Tecnología	Justificación
Repositorio	Monorepo en GitHub (/frontend, /backend, /shared)	Paquete <code>shared</code> con esquemas Zod y tipos comunes
CI	GitHub Actions	Lint + build + tests en cada Pull Request

4. Arquitectura general



Decisiones arquitectónicas clave:

- **API REST** con prefijo `/api/v1`. Contratos documentados con Swagger (decoradores de NestJS) para que ambos desarrolladores trabajen contra la misma definición.
- **Interceptor global de auditoría:** toda petición mutante (POST/PATCH/DELETE lógico) genera automáticamente un registro en `audit_log` con estado previo, estado nuevo, hash del payload y metadatos del usuario. La tabla no expone operaciones UPDATE ni DELETE (append-only), reforzado con triggers en PostgreSQL.
- **Máquina de estados como servicio central** (`OrganizationStateMachine`): única pieza de código autorizada a cambiar el estado de una organización. Cualquier transición fuera de las permitidas lanza excepción y se audita como intento fallido.
- **Mock DIAN mediante interfaz** (`DianProvider`): el MVP implementa `MockDianProvider` con las mismas firmas de método que tendría el proveedor real; el cambio futuro es solo de inyección de dependencias.
- **Soft-delete universal para documentos:** los documentos legales nunca se eliminan físicamente; se marcan `INACTIVO` o `REEMPLAZADO` conservando el histórico completo.

5. Requerimientos funcionales (RF)

Nomenclatura: RF-XX. Prioridad: **M** = Must (obligatorio MVP), **S** = Should (deseable MVP).

5.1 Registro y clasificación

ID	Requerimiento	Prioridad
RF-01	El sistema debe permitir crear una organización con datos básicos de identificación y contacto, iniciando en estado Borrador .	M
RF-02	El sistema debe validar campos obligatorios antes de permitir el envío a revisión, indicando en la interfaz cuáles son obligatorios y cuáles opcionales.	M
RF-03	El sistema debe guardar automáticamente el progreso parcial del formulario y nunca borrar información ya diligenciada ante errores de validación.	M
RF-04	El sistema debe clasificar la organización como Comunitaria/Informal cuando no exista NIT validado ni conjunto documental formal completo, sin impedir su operación básica.	M
RF-05	El sistema debe clasificar la organización como Formal cuando el registro contenga los datos jurídicos mínimos y la revisión administrativa los valide.	M
RF-06	El sistema debe detectar duplicidad por NIT, razón social, cámara de comercio o correo institucional; ante coincidencia debe bloquear el registro y ofrecer: solicitar vinculación, recuperar acceso o abrir incidencia administrativa.	M

5.2 Máquina de estados

ID	Requerimiento	Prioridad
RF-07	Cada organización mantiene dos dimensiones de estado independientes y simultáneas: estado operativo (Borrador, Pendiente, Observado, Aprobado, Rechazado, Suspendido) y estado de formalidad (Comunitaria/Informal, Formal).	M
RF-08	Solo se permiten las transiciones definidas: Borrador→Pendiente; Pendiente→Observado/Aprobado/Rechazado; Observado→Pendiente/Rechazado; Aprobado→Suspendido; Informal→Formal; Formal→Suspendido. Toda otra transición debe rechazarse y auditarse.	M
RF-09	Si un flujo expira por tiempo o inactividad, el sistema conserva el último estado alcanzado y registra el evento de expiración en auditoría. Una	M

ID	Requerimiento	Prioridad
	organización en Observado permanece así hasta decisión administrativa explícita.	
RF-10	La suspensión de una organización restringe su operación pero nunca borra historial ni documentos.	M
RF-11	El sistema debe marcar como INACTIVA a la organización con más de 12 meses sin actividad, bloqueando creación de campañas, donaciones y apadrinamientos nuevos hasta actualización de información.	S

5.3 Formalización progresiva

ID	Requerimiento	Prioridad
RF-12	Una organización comunitaria puede cargar posteriormente NIT, RUT, razón social, Cámara de Comercio, representante legal y documentos asociados para formalizarse, pasando por el estado temporal FORMALIZACIÓN EN REVISIÓN .	M
RF-13	Al formalizarse, la organización conserva su identificador interno; el sistema no debe duplicar el registro. El cambio de formalidad se registra como transición histórica auditable.	M
RF-14	Si la formalización es rechazada, la organización vuelve a COMUNITARIO con las observaciones registradas.	M

5.4 Documentos institucionales

ID	Requerimiento	Prioridad
RF-15	El sistema valida en servidor: tamaño máximo, formato permitido, integridad y ausencia de corrupción. Formatos: Cámara de Comercio/RUT/Certificados → PDF; Logo → PNG, JPG; Firma → PNG.	M
RF-16	Mensajes de error exactos definidos por el cliente: archivo corrupto ("El archivo cargado no puede ser procesado. Intente nuevamente."), formato inválido ("El formato del archivo no es compatible."), tamaño excedido ("El archivo supera el tamaño máximo permitido.").	M
RF-17	El sistema debe identificar documentos vencidos (Cámara de Comercio vencida, RUT desactualizado, certificados expirados) y pasar la organización a Observado con motivo "Documento vencido".	M
RF-18	Ningún documento legal se elimina físicamente: se marca INACTIVO o REEMPLAZADO conservando el histórico completo.	M

5.5 Firma virtual y Representante Legal

ID	Requerimiento	Prioridad
RF-19	El Representante Legal puede cargar su firma virtual (imagen PNG o trazo digital) de forma segura, asociada al perfil institucional.	M

ID	Requerimiento	Prioridad
RF-20	La firma se almacena cifrada en backend (AES-256-GCM); nunca se expone en texto plano, URLs públicas sin protección ni almacenamiento inseguro.	M
RF-21	El sistema captura la identidad real del Representante Legal (nombres, tipo y número de identificación, contacto). Si el nombre no coincide con documentos o la identificación es inconsistente, se genera observación automática (estado Observado).	M
RF-22	Si falla el almacenamiento de la firma: rollback transaccional completo, sin registros parciales, alerta administrativa. El sistema no debe aprobar la organización ni continuar el flujo.	M
RF-23	Firma inválida (ilegible, archivo vacío, imagen dañada, resolución insuficiente) → estado Observado con mensaje "La firma cargada no cumple los requisitos mínimos de validación."	M

5.6 Documentos con firmantes dinámicos

ID	Requerimiento	Prioridad
RF-24	Los participantes de contratos y documentos se resuelven dinámicamente desde los IDs reales en base de datos al momento de generar el documento; prohibidos nombres hardcodeados o participantes genéricos.	M
RF-25	El firmante reflejado en el contrato debe corresponder exactamente al representante legal o delegado vigente en la fecha de la transacción.	M
RF-26	El sistema guarda la relación documento generado ↔ firmantes ↔ entidad origen.	M

5.7 Reportes formales y flujo DIAN

ID	Requerimiento	Prioridad
RF-27	Solo organizaciones Formales pueden generar reportes tributarios y certificados de donación. Cualquier intento desde una organización informal debe bloquearse y auditarse.	M
RF-28	El reporte se genera en plataforma, se estampa con la firma del Representante Legal y se prepara para envío institucional.	M
RF-29	Sin respuesta de DIAN → estado EN PROCESAMIENTO , registrando fecha, hora, payload y número de intento. Reintentos automáticos: 5 min, 30 min, 2 h, 24 h. Fallo definitivo → ERROR DE ENVÍO con notificación: "No fue posible validar el documento ante la DIAN. El sistema realizará nuevos intentos automáticamente."	M
RF-30	Inconsistencia retornada por DIAN (NIT inválido, firma inválida, documento mal formado, error tributario) → estado RECHAZADO POR DIAN : bloquear emisión del certificado, registrar causa exacta, generar incidente administrativo.	M

ID	Requerimiento	Prioridad
RF-31	El documento final validado (con acuse/retorno) se guarda en el repositorio documental. La estructura debe permitir replicación futura a un Data Warehouse.	S
RF-32	Fallo de integración con proveedor externo de firma electrónica (futuro): registrar código de error, timestamp, payload y respuesta; estado PENDIENTE DE VALIDACIÓN ; nunca aprobar automáticamente.	S

5.8 UI, notificaciones y visibilidad

ID	Requerimiento	Prioridad
RF-33	El perfil de la organización y el panel administrativo muestran siempre el estado operativo y el nivel de formalidad.	M
RF-34	El sistema notifica los cambios a Observado, Aprobado, Rechazado, Suspendido o Formal (correo + notificación en plataforma).	M
RF-35	Los estados anteriores nunca se ocultan ni se sustituyen: el historial de estados es consultable.	M

6. Requerimientos no funcionales (RNF)

ID	Requerimiento
RNF-01	Auditoría inmutable: tabla <code>audit_log</code> append-only. Sin endpoints de modificación/eliminación y con triggers de PostgreSQL que rechacen UPDATE/DELETE, incluso para SUPERADMIN.
RNF-02	Retención: registros de auditoría conservados mínimo 10 años (o el período superior que exija la legislación colombiana).
RNF-03	Seguridad de firma: cifrado AES-256-GCM en reposo; claves fuera del código (variables de entorno / gestor de secretos); acceso solo por endpoint autenticado y autorizado.
RNF-04	Transaccionalidad: operaciones críticas (guardado de firma, transiciones de estado, formalización) dentro de transacciones de base de datos con rollback total ante fallo.
RNF-05	RBAC estricto: toda acción se valida contra la matriz de permisos en backend (los controles de UI son solo apoyo visual, nunca la barrera real). Intentos fuera de permiso se bloquean y se auditan.
RNF-06	Trazabilidad: toda entidad relevante conserva <code>created_at</code> , <code>updated_at</code> y referencia al usuario que ejecutó la acción.
RNF-07	Contraseñas con hash bcrypt/argon2; tokens JWT de corta duración con refresh token.
RNF-08	Validación doble: todos los datos se validan en frontend (UX) y nuevamente en backend (seguridad) con los mismos esquemas Zod compartidos.

ID	Requerimiento
RNF-09	Idioma: interfaz y mensajes en español (mensajes de error literales según lo definido por el cliente).
RNF-10	Zona horaria: timestamps almacenados en UTC (requisito explícito del audit_log); presentación en hora de Colombia (UTC-5).

7. Modelo de datos preliminar

Entidades principales (esquema Prisma; el detalle fino se define en la fase de modelado ER):

Entidad	Propósito	Campos clave
User	Usuarios de la plataforma	id (UUID), email, password_hash, role (SUPERADMIN, ADMIN, MANAGER, EMPLOYEE), organization_id (nullable), status
Organization	Entidad central del módulo	id (UUID, permanente), nombre, razón_social, nit (nullable hasta formalizar), correo_institucional, teléfono, dirección, operational_status , formality_status , formalization_status (nullable: EN_REVISION), inactive (bool), created_at
OrganizationStateHistory	Historial de transiciones de estado	id, organization_id, dimension (OPERATIVO/FORMALIDAD), previous_state, new_state, motivo, actor_user_id, timestamp
LegalRepresentative	Identidad real del representante	id, organization_id, nombres, tipo_documento, numero_documento, email, teléfono, activo, vigente_desde/hasta
Signature	Firma virtual cifrada	id, legal_representative_id, encrypted_data (BYTEA), encryption_iv, status (ACTIVA, REVOCADA, REEMPLAZADA), created_at
Document	Documentos institucionales	id, organization_id, tipo (CAMARA_COMERCIO, RUT, CERTIFICADO, LOGO, FIRMA), file_path, mime_type, size, fecha_vencimiento (nullable), status

Entidad	Propósito	Campos clave
Observation	Observaciones de subsanación	(VIGENTE, INACTIVO, REEMPLAZADO, OBSERVADO), replaced_by_id (nullable) id, organization_id, document_id (nullable), motivo, detalle, plazo_subsanacion, resuelta (bool), created_by
GeneratedDocument	Contratos/certificados generados	id, organization_id, tipo, template_version, signers (JSONB con IDs y snapshot de nombres resueltos), file_path, hash, created_at
TaxReport	Reportes tributarios / certificados de donación	id, organization_id, generated_document_id, dian_status (GENERADO, FIRMADO, EN_PROCESAMIENTO, VALIDADO, RECHAZADO_POR_DIAN, ERROR_DE_ENVIO), intentos (JSONB), acuse_file_path (nullable)
AuditLog	Auditoría inmutable	Estructura exacta exigida por el cliente: id, timestamp (UTC), user_id, user_pin, user_role, organization_id, ip_address, user_agent, module, endpoint, action, entity_type, entity_id, previous_state (JSONB), new_state (JSONB), payload_hash, response_code, success, created_at
Notification	Notificaciones de cambios de estado	id, user_id, organization_id, tipo, mensaje, leída, created_at
AdminIncident	Incidencias administrativas	id, organization_id, origen (DUPLICIDAD, DIAN, FIRMA), detalle, estado, asignado_a

8. API — Endpoints preliminares

Prefijo común: `/api/v1`. Autenticación JWT en todos salvo registro y login.

Método y ruta	Descripción	Roles
POST <code>/auth/register</code>	Registro de usuario Manager +	Público

Método y ruta	Descripción	Roles
	organización en Borrador	
POST /auth/login • POST /auth/refresh • POST /auth/logout	Sesión	Público / autenticado
GET /organizations/:id	Perfil institucional con estados	Miembros de la org, Admin, SuperAdmin
PATCH /organizations/:id	Editar perfil (guardado parcial en Borrador)	Manager, Admin, SuperAdmin
POST /organizations/:id/submit	Borrador → Pendiente	Manager
POST /organizations/:id/review	Aprobar / Observar / Rechazar (body: decisión + motivo)	Admin, SuperAdmin
POST /organizations/:id/resubmit	Observado → Pendiente tras subsanación	Manager
POST /organizations/:id/suspend • /reactivate	Suspensión / reactivación	Admin, SuperAdmin
POST /organizations/:id/formalization	Iniciar formalización (carga NIT, RUT, etc.)	Manager
POST /organizations/:id/formalization/review	Aprobar/rechazar formalización	Admin, SuperAdmin
GET /organizations/:id/history	Historial de estados	Manager, Admin, SuperAdmin
POST /organizations/:id/documents	Carga de documento con validaciones	Manager
PATCH /documents/:id/replace	Reemplazo (marca REEMPLAZADO, nunca borra)	Manager
POST /organizations/:id/legal-representative	Registrar identidad del representante	Manager
POST /legal-representatives/:id/signature	Carga de firma (cifrado + transacción)	Manager
POST /organizations/:id/reports	Generar reporte/certificado (solo Formal)	Manager
POST /reports/:id/sign	Estampar firma en reporte	Manager

Método y ruta	Descripción	Roles
POST /reports/:id/send-dian	Encolar envío a DIAN (mock)	Manager
GET /reports/:id/status	Estado del flujo DIAN	Manager, Admin
GET /audit-logs	Consulta de auditoría (solo lectura, filtros)	Admin, SuperAdmin
GET /admin/organizations?status=pendiente	Cola de revisión administrativa	Admin, SuperAdmin
GET /notifications	Notificaciones del usuario	Autenticado

9. Matriz de roles y permisos (definida por el cliente)

Acción	Employee	Manager	Admin	SuperAdmin
Registrar organización	No	Sí	Sí	Sí
Editar perfil institucional	No	Sí	Sí	Sí
Cargar documentos legales	No	Sí	Sí	Sí
Gestionar firma legal	No	Sí	No	Sí
Aprobar organización	No	No	Sí	Sí
Rechazar organización	No	No	Sí	Sí
Suspender organización	No	No	Sí	Sí
Ver auditoría completa	No	No	Sí	Sí
Configuración global	No	No	No	Sí

Nota de implementación: cada fila se implementa como un permiso nombrado (p. ej. `org:approve`, `signature:manage`) verificado por un guard de NestJS; la matriz vive en un archivo de configuración único compartido y testeado.

10. División del trabajo (2 desarrolladores)

Fase conjunta (Semana 1 — obligatoria en pareja)

1. Esquema Prisma completo y migración inicial.
2. Contratos de API (DTOs + esquemas Zod en `/shared`).
3. Esqueleto del monorepo, configuración de lint/format, CI en GitHub Actions y seed de roles.

Desarrollador A — Núcleo institucional

Backend y frontend de: registro de organización y formulario multi-paso con guardado parcial; máquina de estados operativa y su historial; flujo de revisión administrativa (aprobar/observar/rechazar/suspender); formalización progresiva; detección de duplicados; panel administrativo de cola de revisión; notificaciones de cambio de estado.

Desarrollador B — Seguridad y documentos

Backend y frontend de: autenticación JWT + RBAC completo con matriz de permisos; carga y validación de documentos (formatos, tamaño, integridad, vencimiento) y ciclo INACTIVO/REEMPLAZADO; representante legal y firma cifrada (incluyendo rollback transaccional y alertas); módulo de auditoría (interceptor global + consulta); generación de PDF con firmantes dinámicos; reportes tributarios y flujo mock DIAN con reintentos BullMQ.

Dependencias entre desarrolladores

- B entrega auth/RBAC primero (todo lo de A lo consume). Mitigación: en la semana conjunta se deja un guard provisional funcional.
- A entrega la entidad Organization y su máquina de estados antes de que B conecte reportes (los reportes exigen estado Formal). Mitigación: el esquema Prisma conjunto ya define los enums de estado desde el día 1.
- El interceptor de auditoría (B) se integra sobre los endpoints de A: se acuerda desde el inicio que **ningún endpoint mutante hace merge a develop sin pasar por el interceptor**.

11. Flujo de trabajo en GitHub

1. **Ramas:** main (protegida, solo releases) ← develop (integración) ← feature/<área>-<descripción> (p. ej. feature/orgs-state-machine, feature/auth-rbac).
 2. **Pull Requests obligatorios** hacia develop con revisión del otro desarrollador (mínimo 1 aprobación). Regla de oro con Antigravity: *el código generado por IA lo revisa siempre un humano distinto al que lo generó*.
 3. **Convención de commits:** Conventional Commits (feat:, fix:, docs:, refactor:, test:).
 4. **CI en cada PR:** lint + typecheck + tests. PR no se mergea en rojo.
 5. **Migraciones Prisma:** solo se crean en ramas coordinadas; ante conflicto de migración, se resuelve en pareja antes del merge.
 6. **Issues y Projects de GitHub:** cada RF de este documento se convierte en un issue etiquetado (dev-a, dev-b, conjunto) y se gestiona en un tablero Kanban.
-

12. Plan de fases

Fase	Contenido	Duración estimada
0. Planeación	Este documento, diagrama ER, diagrama de máquina de estados, contratos API	1 semana
1. Fundación	Monorepo, Prisma + migración inicial, auth básico, CI, seed	1 semana (conjunta)
2. Iteración 1	Registro de organización, máquina de estados, RBAC completo, panel admin básico	2–3 semanas
3. Iteración 2	Documentos con validaciones, observación/subsanación, firma cifrada, representante legal	2–3 semanas
4. Iteración 3	Formalización, generación de PDF dinámicos, reportes, mock DIAN con reintentos, auditoría consultable	2–3 semanas
5. Estabilización	Pruebas de la máquina de estados y matriz de permisos, correcciones, documentación de despliegue	1 semana

13. Riesgos identificados

Riesgo	Impacto	Mitigación
Conflictos de migración de BD entre los dos devs	Alto	Esquema definido en conjunto en Fase 1; migraciones coordinadas por chat antes de crearlas
Código generado por IA sin revisión suficiente	Alto	PR obligatorio con revisión cruzada; tests mínimos de estados y permisos
Ambigüedad sobre integración DIAN real	Medio	Interfaz <code>DianProvider</code> con mock; contrato de datos documentado para integración futura
Cifrado de firma mal implementado	Alto	Usar AES-256-GCM estándar del módulo <code>crypto</code> ; test específico de que la firma nunca sale en respuestas ni logs
Alcance creciente (otros módulos del cliente)	Medio	Este documento delimita estrictamente el Módulo 1; nuevos módulos = nueva fase de planeación

14. Criterios de finalización del módulo (Definition of Done)

El Módulo 1 se considera terminado cuando: todos los RF de prioridad M están implementados y probados; la máquina de estados rechaza transiciones inválidas con test automatizado; la matriz de permisos tiene test por cada celda; el `audit_log` registra todos los eventos obligatorios (organizaciones, documentos, firma, reportes, usuarios) y es inmutable

a nivel de base de datos; la firma cifrada no es recuperable en texto plano por ninguna ruta; y el flujo mock DIAN completa el ciclo generar → firmar → enviar → reintentar → acuse/rechazo.